K.A.R.M.A · LAB GUIDE

KARMA Decoys and Attacks Guide

Every decoy, trap and honeytoken in KARMA, how an attacker can hit it, and what KARMA records.

Team K.A.R.M.A · The Oxford Evening Polytechnic · Semester VI Diploma Major Project

Decoy services

KARMA runs five fake services. Replace `<KARMA-IP>` with the KARMA PC's IP (usually 192.168.137.1 on its hotspot). An action quarantines the attacker in **Contain** mode only when its risk is 75 or more; everything else is logged and watched.

Decoy	Port	What the attacker sees	How to attack it	What KARMA logs (MITRE · base risk)	Quarantines?
SSH	2222	A real SSH server (Paramiko) with banner `OpenSSH_8.9p1 Ubuntu` ; **any password is accepted**; a fake Ubuntu shell `root@aegis-gateway` with `/root` and `/srv/company`	Scan: `nmap -sT -sV -p 2222 <KARMA-IP>` · Log in: `ssh root@<KARMA-IP> -p 2222` (any password) · Explore: `ls -la` , `cd /srv/company` , `cat contacts.csv` , `cat operations/deploy.env` · Dangerous: `whoami` , `id` , `uname -a` , `cat /etc/passwd` , `wget` , `curl` , `chmod` , `bash -i` · Files: `sftp -P 2222 root@<KARMA-IP>` then `get /root/AEGIS_Financials.xlsm`	Login: T1110 Brute Force · 65, with the client's SSH version (reveals OS) · Normal commands: T1059 · 60 · Dangerous commands: T1059 · 90 · SFTP download: "Decoy file read started"	Login and `ls` / `cd` / `cat` : no · `whoami` , `id` , `cat /etc/…` , `wget` , `curl` : **yes**
Web portal	8080	"Aegis" corporate vault login page; a hidden link "Backdoor Recovery Console (Legacy)"; a `TODO(dev)` comment in the page source naming the API and `deploy.env`	Browse `http://<KARMA-IP>:8080` and view source (Ctrl+U) · `curl http://<KARMA-IP>:8080/robots.txt` · Log in with any username/password · SQL injection: username `' OR 1=1 --` · XSS: `<script>alert(1)</script>` · Probes: `/.env` , `/wp-login.php` , `/phpmyadmin`	Page views, `robots.txt` , normal logins: T1595 Active Scanning · 50–55 · SQL injection, `<script>` , `../../` , `/etc/passwd` : T1190 Exploit Public-Facing App · 85	Browsing and logins: no · Injection: **yes**
FTP	21	`220 Aegis Corporate File Service ready.` ; any user and password logs in; a read-only archive `/srv/company` with `finance` , `reports` , `operations` , `archive`	`ftp -p <KARMA-IP>` (Linux), user `Admin` , any password · `ls` , `cd operations` , `get deploy.env` , `bye` · Windows `ftp.exe` connects but downloads usually fail (active mode only)	Connection: T1046 · 40 · Each command: logged, password redacted · `RETR` (download): T1005 Data from Local System · 60	No (but the downloaded secrets lead to the finale)

Decoy	Port	What the attacker sees	How to attack it	What KARMA logs (MITRE · base risk)	Quarantines?
Telnet	23	`Ubuntu 22.04 LTS aegis-gateway login:` then `Password:` ; **every attempt returns "Login incorrect"** (no shell)	`telnet <KARMA-IP>` (enable the Telnet client on Windows first) and try usernames and passwords; up to 30 tries or 5 minutes	Connection and each login attempt: T1046 · 45 (username kept, password redacted)	No
RDP	3389	Answers the first Remote Desktop handshake, then closes; no desktop	Windows: `mstsc /v:<KARMA-IP>` · Scan: `nmap -sT -sV -p 3389 <KARMA-IP>`	Connection: T1046 · 45; captures the Windows username the client sends (`mstshash=`)	No
Custom decoy	any port you add	A TCP port that accepts the connection and closes it	`nmap -sT -p <port> <KARMA-IP>` or `Test-NetConnection <KARMA-IP> -Port <port>`	Port scan probe: T1046 · 40–45	No

Risk rises by 5 for each repeat attempt from the same IP (up to +30), but a low-risk action is capped at 74, so scanning or guessing passwords alone never quarantines. If Remote Desktop already uses port 3389 on the KARMA PC, the RDP decoy shows **ERROR**; untick it or turn Remote Desktop off.

Web traps and hidden routes (port 8080)

All routes are on the web decoy, `http://<KARMA-IP>:8080`. On Windows, use `curl.exe` (plain `curl` in PowerShell is a different command).

Route	How the attacker finds it	How to hit it	Response	What KARMA logs (MITRE · base risk)	Quarantines?
`/` (login portal)	Port scan finds 8080	Browser, or `curl http://<KARMA-IP>:8080/`	Aegis vault login page	T1595 Active Scanning · 50	No
`POST /login`	The login form	Any username/password; SQL injection `' OR 1=1 --` or `admin' UNION SELECT password FROM users --`	"Invalid Authentication Credentials"	Normal login: T1595 · 50 (password redacted) · Injection: T1190 · 85	Injection: **yes**
`/?id=1 UNION SELECT …`	Guessing parameters	`curl "http://<KARMA-IP>:8080/?id=1+UNION+SELECT+password+FROM+users"`	Login page	T1190 · 85	**Yes**

Route	How the attacker finds it	How to hit it	Response	What KARMA logs (MITRE · base risk)	Quarantines?
`/robots.txt`	Standard recon file	`curl http://<KARMA-IP>:8080/robots.txt`	Lists `Disallow: /secret-vault-admin-login-php` and `Disallow: /api/v1/`	T1595 · 50	No
`/secret-vault-admin-login-php`	`robots.txt` and the "Backdoor Recovery Console (Legacy)" link on the portal	Click the link, or `curl http://<KARMA-IP>:8080/secret-vault-admin-login-php`	`403 Access Denied - Security Alert Triggered`	Honeytoken URL: T1078 Valid Accounts · 95; Honeytoken Vault hit counter +1	**Yes**
`/api/v1/auth/keys`	`robots.txt` and the `TODO(dev)` comment in the page source	`curl http://<KARMA-IP>:8080/api/v1/auth/keys`	`403 Access denied`	API trap: T1078 · 95; counts as a hit on the AWS decoy key	**Yes**
`/api/v1/admin/db_export`	The `TODO(dev)` comment says to send the deploy key in `X-API-Key`	`curl -H "X-API-Key: <API_KEY from deploy.env>" http://<KARMA-IP>:8080/api/v1/admin/db_export`	`403 Access denied`	Stolen key used: T1078 · 95; records which key was used	**Yes**
`/.env`, `/wp-login.php`, `/phpmyadmin`	Automated scanners and wordlists	`curl http://<KARMA-IP>:8080/.env`	`404 Not Found`	T1595 · 55	No
Path traversal `../../etc/passwd`	Classic web attack	`curl --path-as-is "http://<KARMA-IP>:8080/../../etc/passwd"`	`404 Not Found`	T1190 · 85	**Yes**
Any other path	Directory guessing	`curl http://<KARMA-IP>:8080/anything`	`404 Not Found`	T1595 · 50	No

The two API traps can be switched off separately in **Honeypot & Decoy Control**; switched off, they return `404` and log nothing. Use `nmap -sT -sV` (connect scan) so Nmap actually sends an HTTP request; a bare SYN scan is never logged.

Honeytokens and decoy files

Honeytokens are fake secrets planted to be stolen. Nobody legitimate knows them, so the moment one is used, KARMA knows it was stolen from a decoy. Every hit shows up in the **Honeytoken Vault** tab with a hit counter and the attacker's IP.

Bait	Value	Where it is planted	How the attacker steals it	How they use it	What fires	Quarantines?
Decoy AWS API key (`ht-aws-01`)	`AKIAIOSFODNN7EXAMPLE_DECOY_KEY_99`	`API_KEY=` line of `/srv/company/operations/deploy.env`	SSH `cat /srv/company/operations/deploy.env` , or FTP `cd operations` + `get deploy.env`	`curl -H "X-API-Key: <key>" http://<KARMA-IP>:8080/api/v1/admin/db_export` (also accepted as `Authorization` header or `?api_key=`)	T1078 Valid Accounts · 95; vault hit on the key	**Yes**
Staging SSH password (`ht-ssh-key`)	user `root` , password `SuperSecretStaging2026!`	`STAGING_SSH=` line of the same `deploy.env`	Same as above	`ssh root@<KARMA-IP> -p 2222` with that password	T1078 · 95 "Honeytoken credentials used"; the login is then refused	**Yes**
Hidden admin URL (`ht-admin-url`)	`/secret-vault-admin-login-php`	`robots.txt` and the "Backdoor Recovery Console (Legacy)" link on the portal	Reading `robots.txt` or the page	Open the URL	T1078 · 95; "403 Access Denied - Security Alert Triggered"	**Yes**
API endpoint	`/api/v1/auth/keys`	`robots.txt` and the `TODO(dev)` comment in the portal's source	Viewing page source (Ctrl+U)	`curl http://<KARMA-IP>:8080/api/v1/auth/keys`	T1078 · 95; counts as a hit on the AWS key	**Yes**
Custom honeytoken	Any name you create	Honeytoken Vault → Create token; plant the generated value anywhere	Depends where you plant it	Use the value in a web request or open the URL	T1078 · 95	**Yes**
AEGIS decoy documents	`AEGIS_Financials.xlsm` , `AEGIS_Letterhead.docm` , `AEGIS_Project_Atlas_Pitch.pptm`	`/root` and `/srv/company` on the SSH and FTP decoys	`sftp -P 2222 root@<KARMA-IP>` then `get /root/AEGIS_Financials.xlsm` (or FTP `get`)	Open the file on the attacker PC and click **Enable Content**	Download: "Decoy file read started" alert (SFTP) or T1005 (FTP). The macro runs only on the attacker's PC: Notepad greeting + PowerShell `whoami` ; nothing is sent back	No

The full demo story: scan → read `robots.txt` and the `TODO(dev)` comment → SSH in with any password → `cat` the `deploy.env` file → use the stolen API key or staging password → KARMA quarantines the attacker, and every new attempt shows as **BLOCKED**.

Notes for the demo

- **Reset first.** Press **Reset System** before every rehearsal and the real demo: it clears data, unblocks every IP and sets **Contain** mode.
- **Contain vs Observe.** Contain quarantines on risk 75 or more. Observe logs everything and never blocks, so you can explore the fake shell freely or rehearse.
- **After a quarantine,** every new attempt from that IP is refused and logged as **BLOCKED** (at most one entry per port every 10 seconds). SSH shows `Connection reset`. Unblock in **Attacker Profiles** to continue.
- **One finale per attacker.** Each finale in the tables above quarantines the attacker, so use a different one for each attacker PC, or unblock between them.
- **Linux vs Windows attacker.** Use `nmap -sT -sV` (connect scan) on Linux. On Windows, use `Test-NetConnection <KARMA-IP> -Port 2222`, `curl.exe`, and SSH with `-o UserKnownHostsFile=NUL`. Windows `ftp.exe` can log in but usually can't download, so read `deploy.env` over SSH instead.
- **Attacker on another network.** Press **Start Tunnel** in Honeypot & Decoy Control and use the `bore.pub:<port>` addresses instead of `<KARMA-IP>` and the normal port. Every tunnelled attacker appears as `127.0.0.1`, and FTP downloads don't work through the tunnel.
- **Show the result.** After the attack, open **Threats Overview → Adversary Forensic Profiler**: ▶ **Replay** plays back the session and 📄 **Report** gives the printable incident report.
- **Only on networks you own.** Run the decoys only on the lab PC and hotspots you control.